

1. Threat Hunting Methodologies:

1.1 Overview:

Threat hunting is a proactive cybersecurity approach focused on identifying hidden threats that evade traditional security controls. Unlike reactive incident response, threat hunting involves actively searching for Indicators of Compromise (IoCs) and attacker behaviors within an organization's environment.

Frameworks like MITRE ATT&CK provide structured techniques and tactics (TTPs) such as **T1078 – Valid Accounts**, which help analysts detect adversarial behavior patterns.

1.2 Core Concepts:

1.2.1 Proactive Threat Hunting:

Proactive threat hunting is hypothesis-driven and focuses on identifying suspicious activities before alerts are triggered.

- **Hypothesis Example:** "An attacker may be us." AnCase: Analyze authentication logs to detect:
 - Unusual login times.
 - Privilege escalation anomalies.
 - Access from unfamiliar locations.

1.2.2 Threat Hunting Frameworks:

To standardize hunting processes, structured frameworks are used:

- **SqRR (Search, Query, Retrieve, Respond):**
 - **Search:** Identify suspicious patterns.
 - **Query:** Use SIEM tools to investigate logs.
 - **Retrieve:** Collect relevant evidence.
 - **Respond:** Take remediation actions.

- **TaHiTI (Targeted Hunting Integrating Threat Intelligence):**
 - Integrates threat intelligence feeds.
 - Focuses on known adversary behaviors.
 - Enhances detection accuracy through contextual data.

1.2.3 Data Sources for Threat Hunting:

Effective threat hunting relies on multiple data sources:

- **Endpoint Data (EDR):**
 - Process execution logs.
 - File modifications.
 - Registry changes.
- **Network Traffic:**
 - DNS queries.
 - HTTP/HTTPS traffic.
 - Suspicious IP communications.
- **Security Logs:**
 - Authentication logs (e.g., failed logins, privilege changes).
 - System event logs.
- **Threat Intelligence Feeds:**
 - Known malicious IPs/domains.
 - Malware signatures.
 - Adversary TTPs.

1.3 Key Objectives

The primary objectives of threat hunting include:

- Proactively identifying hidden threats.
- Detecting advanced persistent threats (APTs).
- Reducing dwell time of attackers.
- Enhancing overall security posture.
- Developing analytical and investigative skills.

1.4 Learn expertise approach:

To build expertise in SqRR threat hunting, the following resources and methods were used:

- Studied SqRR and TaHiTI frameworks through research papers from the SANS Institute.
- Explored real-world case studies such as APT29 campaigns using MITRE ATT&CK.
- Reviewed practical threat hunting techniques from Elastic's security documentation.
- Practiced log analysis and hypothesis-based hunting in lab environments.

1.5 Practical Application (Internship Experience)

During the internship, threat hunting activities included the following:

- Analyzing SIEM logs to detect abnormal login behavior.
- Identifying brute-force attack patterns using failed login attempts.
- Investigating suspicious processes in endpoint logs.
- Correlating threat intelligence with internal network activity.

SOC Architecture Diagram & Threat Hunting Workflow Diagram

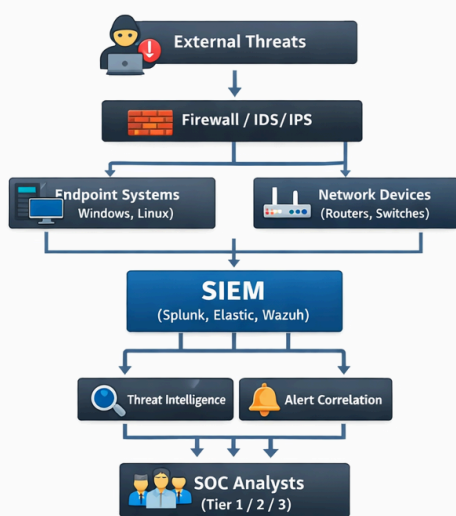


Figure 1: SOC Architecture



Figure 2: Threat Hunting Workflow

2. Advanced SOAR Automation:

2.1 Overview:

Security Orchestration, Automation, and Response (SOAR) enhances SOC efficiency by automating repetitive tasks and integrating multiple security tools into unified workflows. SOAR platforms help reduce response time, improve consistency, and minimize human error in incident handling.

Modern SOC environments integrate SOAR with SIEM and EDR tools such as Wazuh and Elastic Security to streamline detection and response processes.

2.2 Core Concepts:

2.2.1 SOAR Components:

SOAR consists of three key components:

- **Orchestration:**
 - Integrates multiple security tools and systems.
 - Enables seamless data sharing between SIEM, EDR, and ticketing systems.
- **Automation:**
 - Automates repetitive SOC tasks.
 - Examples:
 - Auto-ticket creation.
 - Alert enrichment (e.g., IP reputation lookup).
- **Response:**
 - Executes predefined actions to mitigate threats
 - Examples:
 - Blocking malicious IPs.
 - Isolating infected endpoints.

2.2.2 Playbook Development:

Playbooks are automated workflows designed to handle specific security incidents.

Example: Phishing Response Playbook:

1. Detect a phishing alert from SIEM.
2. Extract email indicators (IP, domain, attachments).
3. Query threat intelligence sources.

4. Automatically block emails from .us domains/IPs.
5. Quarantine suspicious email.
6. Notify SOC analyst.
7. Generate an incident report.

Example: Malware/C2 Detection Playbook

- Detect outbound traffic to suspicious IP.
- Validate against threat intelligence.
- Block IP at firewall.
- Isolate endpoint via EDR.
- Trigger alert escalation.

2.2.3 Integration with SIEM and EDR:

SOAR platforms integrate with multiple tools to automate workflows:

- **SIEM Integration:**
 - Collect alerts and trigger playbooks.
 - Example: Alerts from Elastic Security initiate automated responses.
- **EDR Integration:**
 - Execute endpoint-level actions.
 - Example: Isolate compromised system via Wazuh.
- **Threat Intelligence Integration:**
 - Enrich alerts with real-time data.
 - Validate IoCs automatically.

2.3 Key Objectives:

The main objectives of implementing SOAR include:

- Automating repetitive SOC tasks.
- Reducing incident response time.
- Improving detection and response consistency.
- Enhancing SOC team productivity.
- Minimizing manual errors.

2.4 Learning Approach:

To gain expertise in SOAR automation, the following methods were used:

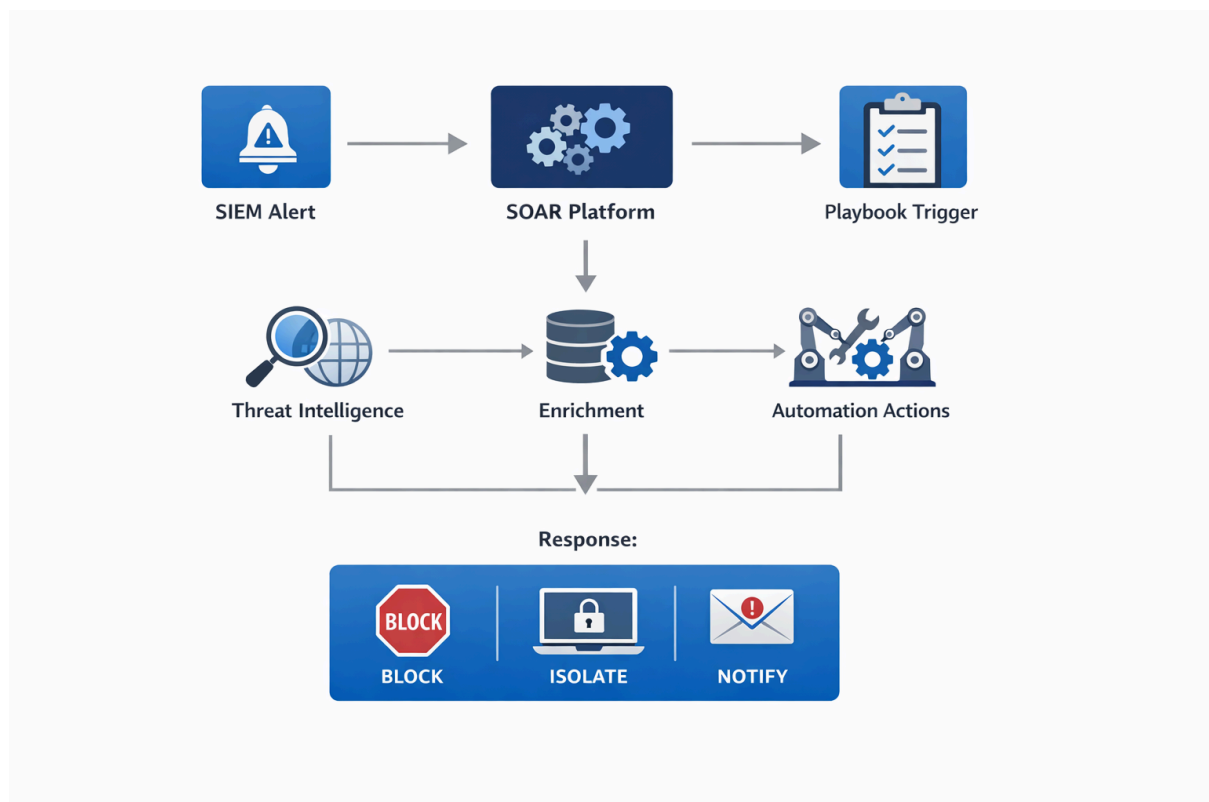
- Studied SOAR concepts and workflows through Splunk SOAR documentation.
- Reviewed playbook implementations from TheHive Project.
- Analyzed automation case studies such as phishing response workflows from CISA.
- Explored integration of SIEM and EDR tools in lab environments.

2.5 Practical Application (Internship Experience):

During the internship, SOAR-related activities included:

- Designing basic playbooks for phishing and brute-force detection.
- Automating alert enrichment using threat intelligence feeds.
- Integrating SIEM alerts with response actions.
- Simulating automated incident response workflows.

Soar Workflow Diagram:



3. Post-Incident Analysis and Continuous Improvement:

3.1 Overview

Post-incident analysis is a critical phase in the incident response lifecycle that focuses on understanding what happened, why it happened, and how to prevent similar incidents in the future. It helps organizations strengthen their security posture by identifying gaps in detection, response, and prevention mechanisms.

Frameworks such as NIST guidelines (e.g., incident handling best practices) emphasize the importance of continuous improvement after every security incident.

3.2 Core Concepts

3.2.1 Root Cause Analysis (RCA)

Root cause analysis is used to identify the underlying cause of a security incident rather than just addressing its symptoms.

Common RCA Techniques:

- **5 Whys Method:**
 - Repeatedly ask “Why?” to trace the root cause
 - Example:
 - Why was the system compromised? → User clicked phishing link
 - Why did they click? → Email appeared legitimate
 - Why was it not blocked? → Weak email filtering rules
- **Fishbone Diagram (Ishikawa):**
 - Categorizes causes into areas such as:
 - People
 - Process
 - Technology
 - Environment

Example Use Case:

A phishing attack reveals the following:

- Lack of user awareness training
- Ineffective email filtering
- Missing multi-factor authentication (MFA)

3.2.2 Lessons Learned Process:

The lessons learned phase involves reviewing the incident to improve future response and prevention.

Key Activities:

- Conduct post-incident meetings (post-mortems)
- Document timeline of events
- Identify what worked well and what failed
- Update:
 - Detection rules
 - Playbooks
 - Security policies

Outcome:

- Improved incident response readiness
- Better coordination among SOC teams
- Reduced chances of recurrence

3.2.3 Metrics and KPIs:

SOC performance is measured using key metrics:

- **Mean Time to Detect (MTTD):**
 - Time taken to identify a threat
- **Mean Time to Respond (MTTR):**
 - Time taken to contain and remediate an incident
- **Other Metrics:**
 - Alert: false positive rate
 - Alert: Ent volume trends
 - Time to containment

3.3 Key Objectives:

The primary objectives of post-incident analysis include:

- Identifying root causes of incidents
- Improving detection and response capabilities
- Reducing future incident impact
- Enhancing SOC processes and workflows
- Supporting continuous security improvement

3.4 Learning Approach:

To develop knowledge in post-incident analysis, the following methods were used:

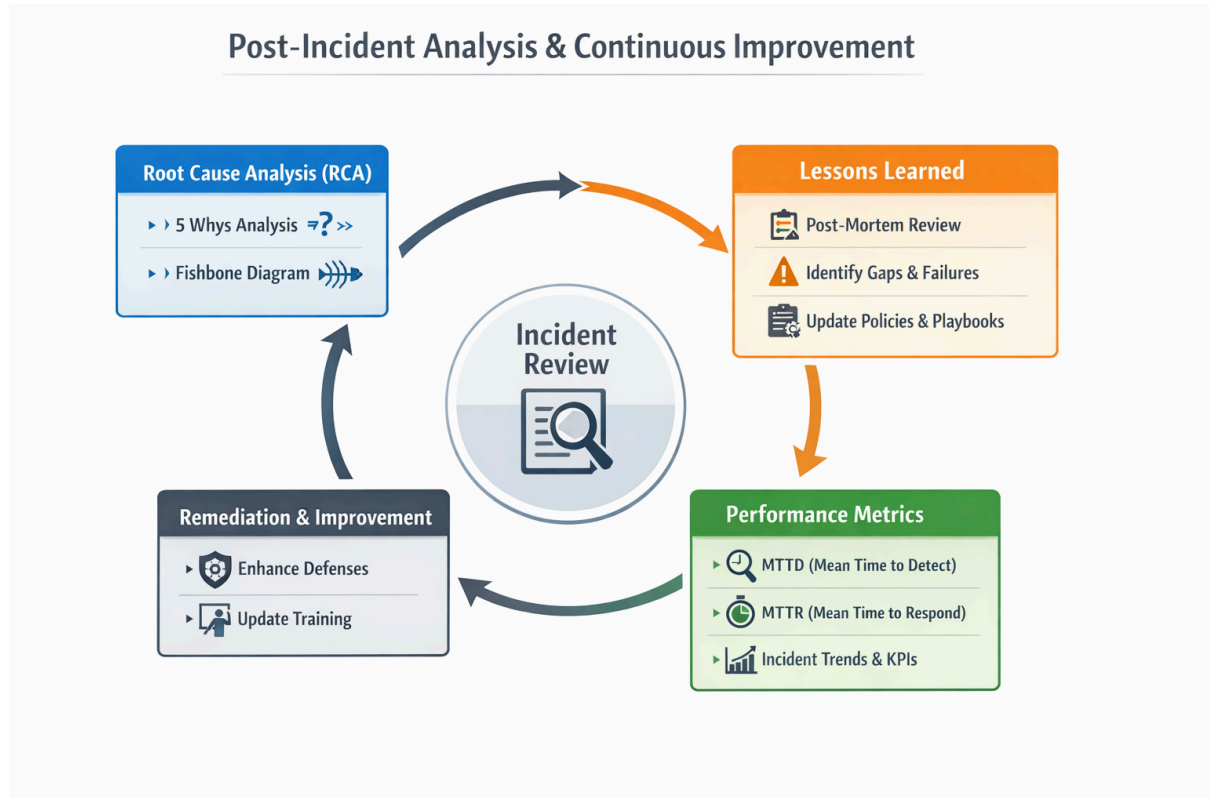
- Studied incident handling guidelines from NIST
- Learned RCA techniques such as 5 Whys and Fishbone analysis
- Reviewed real-world breach case studies
- Analyzed SOC metrics to understand performance evaluation

3.5 Practical Application (Internship Experience):

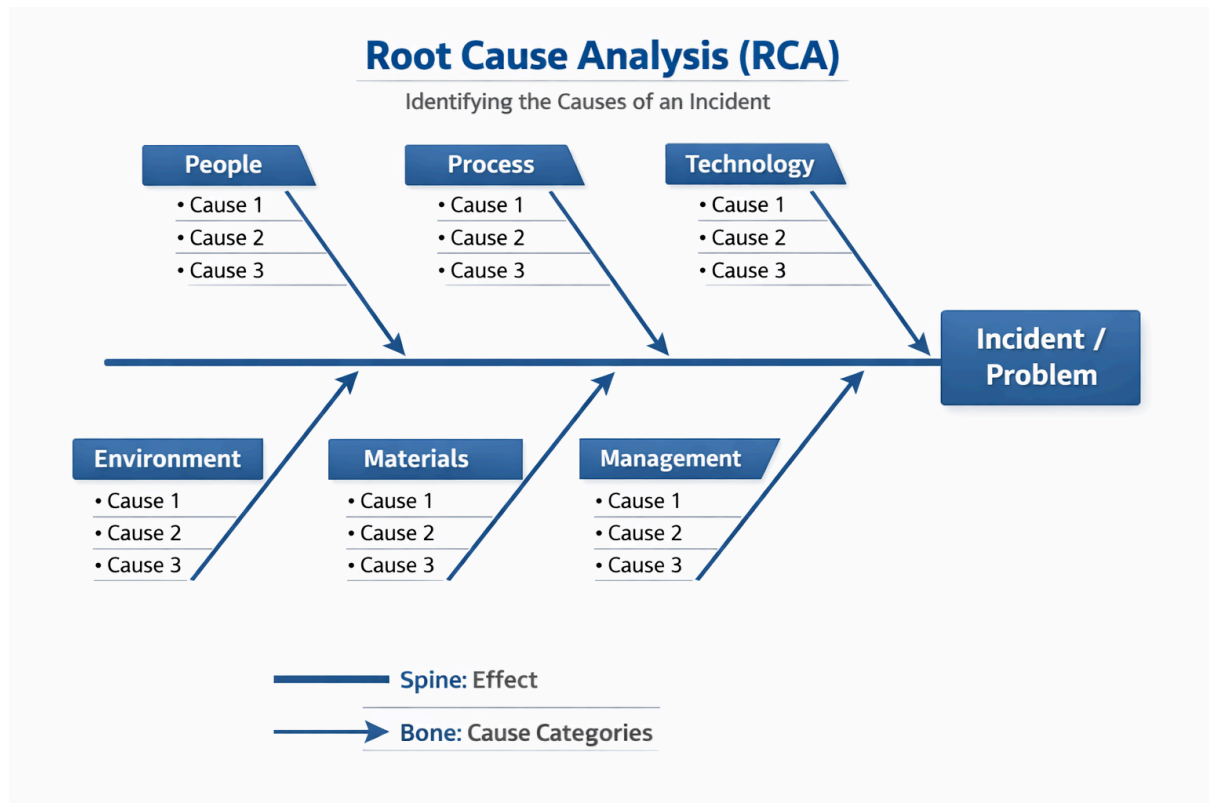
During the internship, post-incident activities included:

- Performing basic Root Cause Analysis on simulated attacks
- Documenting incident timelines and response actions
- Identifying gaps in detection and response workflows
- Suggesting improvements to SIEM rules and playbooks

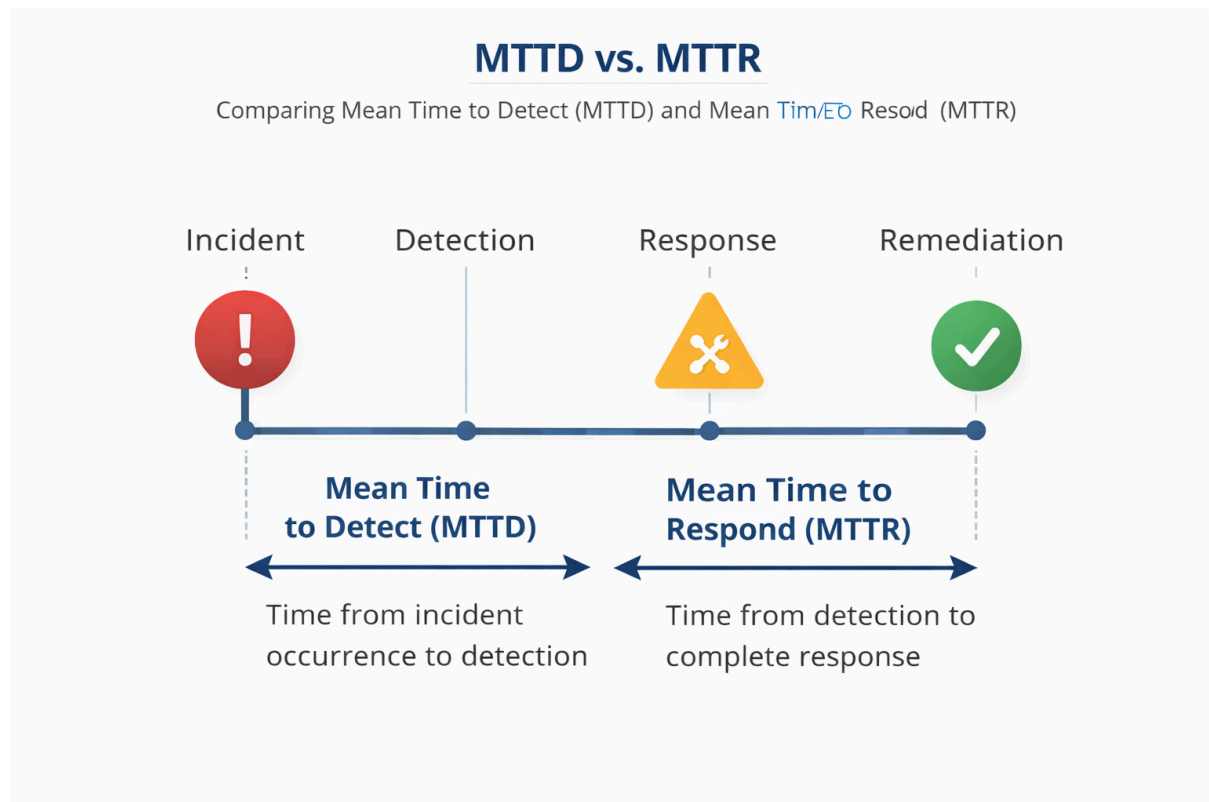
A) Post-Incident Lifecycle Flow:



B) RCA Fishbone Diagram:



C) MTTD vs. MTTR visualization:



4. Adversary Emulation Techniques:

4.1 Overview:

Adversary emulation is a cybersecurity practice that involves simulating real-world attacker behaviors to evaluate and improve an organization's detection and response capabilities. By replicating known attacker techniques, SOC teams can identify gaps in monitoring, detection rules, and incident response processes.

Frameworks like MITRE ATT&CK provide structured mappings of adversary tactics, techniques, and procedures (TTPs), such as the following:

- **T1566 – Phishing**
- **T1210 – Exploitation of Remote Services**

4.2 Core Concepts:

4.2.1 Adversary Emulation

Adversary emulation involves replicating attacker behaviors in a controlled environment.

Key Examples:

- **Phishing Simulation (T1566):**
 - Send controlled phishing emails to test user awareness and email filtering systems.
- **Remote Exploitation (T1210):**
 - Simulate exploitation of vulnerable services to test detection mechanisms.

Purpose:

- Identify detection gaps.
- Validate security controls.
- Improve SOC readiness.

4.2.2 Emulation Frameworks:

Several tools and frameworks are used for adversary simulation:

- **MITRE Caldera**
 - Automated adversary emulation platform.
 - Uses ATT&CK-based TTPs.
 - Supports plugin-based attack scenarios.
- **Features:**
 - Automated attack chains.
 - Realistic threat simulation.
 - Integration with SOC tools.

Example Use Case:

- Simulate a spear-phishing attack.
- Execute payload.
- Observe detection in SIEM/EDR.
- Evaluate response time.

4.2.3 Red-Blue Team Collaboration

Adversary emulation strengthens collaboration between:

- **Red Team (Attackers):**
 - Simulate real-world attacks
 - Execute TTPs
- **Blue Team (Defenders):**
 - Detect and respond to attacks
 - Improve monitoring and alerts

Outcome:

- Enhanced detection rules.
- Improved incident response.
- Better SOC coordination.

4.3 Key Objectives

The main objectives of adversary emulation include:

- Simulating real-world attack scenarios.
- Validating detection and response capabilities.
- Identifying gaps in security controls.
- Improving SOC preparedness.
- Enhancing threat detection accuracy.

4.4 Learning Approach:

To build expertise in adversary emulation, the following methods were used:

- Explored emulation workflows using MITRE Caldera.
- Studied adversary techniques via MITRE ATT&CK.
- Reviewed real-world case studies such as APT28 campaigns.
- Analyzed practical approaches from Red Canary emulation guides.

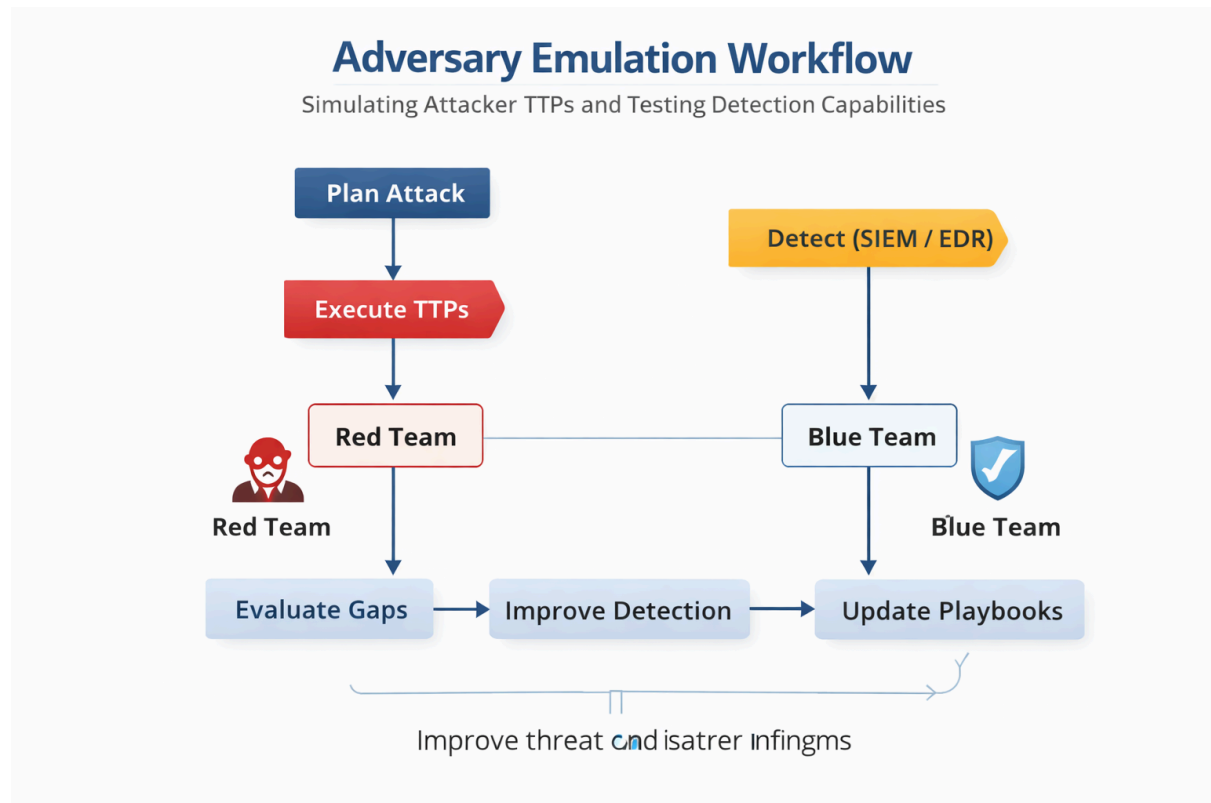
4.5 Practical Application (Internship Experience):

During the internship, adversarial emulation activities included:

- Simulating phishing attacks in a controlled lab environment.
- Testing detection of suspicious login attempts and lateral movement.
- Evaluating SIEM alert generation and response workflows.
- Identifying gaps in detection rules and suggesting improvements.

These activities helped in understanding attacker behavior and improving SOC defensive strategies.

Adversary Emulation Workflow Diagram:



5. Security Metrics and Executive Reporting:

5.1 Overview

Security metrics and executive reporting are essential for evaluating SOC performance and communicating security posture to organizational leadership. Metrics provide measurable insights into detection and response efficiency, while executive reporting translates technical findings into actionable business insights.

Standards and guidance from organizations like the SANS Institute and CISA help define effective SOC metrics and reporting practices.

5.2 Core Concepts

5.2.1 Advanced SOC Metrics

SOC performance is measured using key advanced metrics:

- **Dwell Time:**
 - Time between initial compromise and detection
 - Lower dwell time = better detection capability
- **False Positive Rate:**
 - Percentage of alerts that are not actual threats
 - A high rate indicates inefficient detection rules
- **Incident Resolution Rate:**
 - Percentage of incidents successfully resolved
 - Measures SOC effectiveness
- **MTTD (Mean Time to Detect):**
 - Time taken to identify threats
- **MTTR (Mean Time to Respond):**
 - Time taken to contain and remediate incidents

5.2.2 Executive Reporting

Executive reporting focuses on presenting security data in a clear, non-technical manner.

Key Elements:

- Visual dashboards (charts, graphs)
- Summary of key incidents
- Trends over time (monthly/weekly)
- Risk impact analysis

Best Practices:

- Use simple language (avoid technical jargon)
- Highlight business impact
- Provide actionable recommendations

5.2.3 Continuous Improvement Using Metrics

Metrics are used to identify gaps and improve SOC operations:

- High **MTTD** → Improve detection rules and monitoring
- High **MTTR** → Optimize response workflows and automation
- High **False Positives** → Tune SIEM correlation rules

- Long **Dwell Time** → Enhance threat hunting capabilities

5.3 Key Objectives

The main objectives of security metrics and reporting include:

- Measuring SOC performance accurately
- Identifying gaps in detection and response
- Supporting data-driven decision-making
- Communicating security posture to leadership
- Driving continuous improvement

5.4 Learning Approach

To develop expertise in this area, the following methods were used:

- Studied SOC metrics from SANS Institute resources (e.g., *Measuring SOC Success*)
- Reviewed reporting frameworks from CISA
- Explored executive reporting templates and dashboards
- Analyzed real-world SOC performance reports

Security Metrics Dashboard Diagram:

Security Metrics Dashboard

SOC Performance Overview (Last 30 Days)

